Bouwplan: inloggen via Canvas (LTI 1.3) en open cursussen voor externen

LEAP-VU · opgesteld 13 oktober 2026 · status: **plan, nog niet gebouwd** · bedoeld als opdracht voor Claude wanneer we gaan bouwen, en als achtergrond voor Lothar, Jasper en Rob

> **Hoe dit document te gebruiken.** Geef dit PDF aan Claude met de opdracht "bouw fase 1" (of een andere fase). Hoofdstuk 13 is de bouwchecklist. Hoofdstuk 12 noemt wat bij de start eerst opnieuw gecontroleerd moet worden, omdat de code sinds 13 oktober 2026 veranderd kan zijn.

Inhoud

1. Doel en genomen besluiten
2. Hoe het nu werkt (bevindingen)
3. Doelbeeld: twee soorten cursussen, twee soorten accounts
4. Datamodel (migraties)
5. Toegangsregels aanpassen
6. Inloggen via Canvas (LTI 1.3)
7. Registratie voor externen
8. Open variant van een cursus
9. Beheer, teksten en documentatie
10. Configuratie: wat Rob nodig heeft
11. Privacy
12. Eerst opnieuw controleren bij de start
13. Bouwchecklist, tests en fasering

1. Doel en genomen besluiten

Doel. VU-studenten en -docenten openen LEAP vanuit Canvas en komen direct, ingelogd, in de bijbehorende LEAP-cursus. Ze hebben geen eigen LEAP-account of registratie meer nodig. Daarnaast kan LEAP *open* cursussen aanbieden aan externen, die zich daarvoor zelf registreren, zonder dat ze iets zien van of terechtkomen in de gesloten VU-cursussen.

Besluit (Lothar, 13-10-2026)	Uitwerking in dit plan
Rollen: **optie A**	Een *Instructor* of *TA* uit Canvas wordt docent van die LEAP-cursus (`course_members.member_role = 'teacher'`). Was zijn account nog `student`, dan wordt het automatisch `docent` (vastgelegd in `user_audit_log`). Nooit automatisch `admin`.
Canvas mag **naam, e-mail en VUnetID** meesturen	Privacyniveau "public" bij de registratie in Canvas, plus het extra veld `vunetid=$Canvas.user.loginId`. Gebruikt om bestaande accounts te herkennen en om namen te tonen waar de privacyregel dat toestaat.
Gesloten VU-cursussen naast open cursussen voor externen	Elke cursus krijgt een *publiek*: `vu` (gesloten, gekoppeld aan Canvas, alleen voor leden) of `open` (zichtbaar voor iedereen met een LEAP-account, zelf aanmelden kan). Externen registreren zich zelf en zien alleen open cursussen. Dezelfde inhoud kan als *open variant* naast een VU-cursus bestaan, zonder de Canvas-cursus te vervuilen.

2. Hoe het nu werkt (bevindingen, 13-10-2026)

- **Inloggen** loopt via de zelf gehoste Supabase-inlogdienst (GoTrue) op Azure. Zelfregistratie staat open (`GOTRUE_DISABLE_SIGNUP=false` in `azure/scripts/deploy.sh`): de inlogpagina roept `supabase.auth.signUp`

aan (`src/contexts/AuthContext.tsx`, `src/pages/LoginPage.tsx`). Een nieuw account krijgt een profiel via de trigger `handle_new_user()`.

- **Accounts in bulk** voor een cursus: `server/bulkAccounts.js` + route in `server/index.js` (uitnodiging per e-mail met activatielink).
- **Lidmaatschap**: `course_members(user_id, course_id, member_role 'student'|'teacher')`.
- **Zichtbaarheid (belangrijk)**: iedere ingelogde gebruiker ziet *alle* cursussen die actief en `student_visible` zijn (policy "Students see available courses, teachers see own" op `courses`), en mag de inhoud ervan gebruiken: `course_content_is_public()` wordt gebruikt in de leesregels voor documenten en fragmenten, in `sc_can_read_course()` (Studiecafé), in `leap_can_use_course()` en in de server (`userHasCourseAccess`, `canAccessCourseContent`). Zelfgeregistreerde studenten (Task #272) hebben daardoor vaak géén `course_members`-rij. **Met externen erbij zou iedere externe dus alle VU-cursussen zien.** Deze regel moet om (hoofdstuk 5).
- **Documenten aan een cursus**: via `course_folder_assignments` (map → cursus). `folder_course_id(folder)` neemt bij meerdere cursussen per map willekeurig één (`LIMIT 1`). Een map met dezelfde documenten aan een VU-cursus én een open variant hangen werkt daardoor nu niet betrouwbaar (hoofdstuk 8).
- **Rolbeveiliging**: trigger `pr_guard_profile_role` voorkomt dat gebruikers hun eigen rol wijzigen; alleen beheerder of server (service role).
- **Inlogcache**: `server/authCache.js` (30 s). Na het verwijderen of blokkeren van een account: `userCache.forgetUser(id)` en `profileCache.invalidate(id)`.
- **E-mail**: account-e-mails via `server/authEmailHook.js` (Azure Communication Services).
- **Eén replica** op Azure; in-memory staat moet in de database als die een herstart moet overleven.

3. Doelbeeld: twee soorten cursussen, twee soorten accounts

	VU-cursus (`audience = 'vu'`)	**Open cursus (`audience = 'open'`)**
Bedoeld voor	VU-studenten en -docenten van één Canvas-cursus	Externen (en desgewenst ook VU'ers)
Hoe word je lid	Automatisch bij openen vanuit Canvas; uitzonderlijk door een beheerder/docent toegevoegd	Zelf aanmelden met de knop "Deelnemen", of toegevoegd door docent
Wie ziet hem in de cursuskeuze	Alleen leden, docenten en beheerders	Iedereen met een LEAP-account
Wie mag de inhoud gebruiken	Alleen leden (+ docenten, beheerders)	Leden; zichtbaar maar pas te gebruiken na "Deelnemen"
Koppeling met Canvas	Eén of meer Canvas-cursussen	Nooit

	VU-account (`account_type = 'vu'`)	**Extern account (`account_type = 'external'`)**
Ontstaat via	Canvas (LTI), bulkaanmaak door docent, of beheerder	Zelfregistratie op de inlogpagina
Inloggen	Via Canvas; bestaande accounts met wachtwoord blijven ook werken (docenten, beheerders)	E-mail + wachtwoord
Kan lid worden van	VU-cursussen (via Canvas) en open cursussen	Alleen open cursussen

Grenzen die altijd gelden: een extern account kan nooit lid worden van een VU-cursus (database-regel, niet alleen in de interface). VU-adressen (`@vu.nl`, `@student.vu.nl`, lijst instelbaar) kunnen zich niet als extern registreren; zij krijgen de melding "Log in via Canvas".

4. Datamodel (migraties)

Elke migratie volgens CLAUDE.md: naam `<YYYYMMDDHHMMSS>_<naam>.sql`, precies één keer uitvoerbaar, terugdraaiscript in `supabase/rollback/`, eindigt met `NOTIFY pgrst, 'reload schema';`, vóór het uitvoeren een momentopname met `scripts/db-snapshot.mjs` van de tabellen die veranderen.

4.1 Migratie `…_course_audience_and_account_type`

```
ALTER TABLE courses  ADD COLUMN audience text NOT NULL DEFAULT 'vu'
  CHECK (audience IN ('vu','open'));
ALTER TABLE profiles ADD COLUMN account_type text NOT NULL DEFAULT 'vu'
  CHECK (account_type IN ('vu','external'));
-- Bestaande accounts: VU-adres → 'vu', anders 'external' (lijst VU-domeinen
-- in een tabel app_settings of als constante in de migratie).
-- Guard: pr_guard_profile_role uitbreiden zodat ook account_type alleen door
-- beheerder/server te wijzigen is.
-- Database-regel: course_members INSERT/UPDATE weigert een extern account in
-- een cursus met audience 'vu' (trigger course_member_audience_guard).
```

Overgang (backfill) — belangrijk. Na deze migratie zien gebruikers zonder lidmaatschap hun VU-cursus niet meer. Daarom in dezelfde migratie: een `course_members`-rij (student) voor elke gebruiker die in die cursus actief was: `profiles.last_active_course_id`, of rijen met die `course_id` in `quiz_attempts`, `learning_journal_entries`, `student_explanations`, `student_course_levels`, `conversations` (indien course_id aanwezig), of lid van een projectgroep in die cursus. Eerst een droge run met aantallen per cursus tonen aan Lothar.

4.2 Migratie `…_lti`

```
lti_platforms      (id, issuer, client_id, auth_login_url, auth_token_url,
                    jwks_url, deployment_ids text[], active bool, created_at)
lti_identities     (id, platform_id → lti_platforms, sub text, user_id → auth.users
                    ON DELETE CASCADE, vunetid text, created_at, last_launch_at,
                    UNIQUE(platform_id, sub))
lti_course_links   (id, platform_id, deployment_id, context_id text,
                    context_title text, course_id → courses ON DELETE CASCADE,
                    linked_by uuid, created_at,
                    UNIQUE(platform_id, deployment_id, context_id))
lti_launch_states  (state text PK, nonce text, created_at, expires_at)  -- 10 min
lti_handover_codes (code_hash text PK, user_id, session jsonb (versleuteld),
                    target text, expires_at, used_at)                  -- 60 s, eenmalig
```

Alle vijf: RLS aan, **geen** policies (alleen de server leest en schrijft). `lti_platforms` is één rij voor VU-Canvas; de waarden komen van Rob (hoofdstuk 10). Opruimen van verlopen states/codes: bij elke start (geen timer nodig).

5. Toegangsregels aanpassen

Kern: "actief en zichtbaar" betekent niet meer "voor iedereen". Eén nieuwe centrale functie, en de bestaande functies gebruiken die.

```
course_open_to_user(course)  = actief AND student_visible AND audience = 'open'
user_is_course_member(course) = course_members-rij van auth.uid()
user_can_use_course(course)   = admin OR is_course_teacher OR
                                (actief AND student_visible AND user_is_course_member)
                                -- open cursus: ook na "Deelnemen" via lidmaatschap
```

Plek	Nu	Wordt
Policy `courses` SELECT	actief + zichtbaar, of docent	docent/admin, **of** lid (actief + zichtbaar), **of** `course_open_to_user`
`course_content_is_public()`	actief + zichtbaar	vervangen door `user_can_use_course()` in alle policies die hem gebruiken (documenten, fragmenten, documentdoelen)
`sc_can_read_course()` (Studiecafé)	actief + zichtbaar, of lid	`user_can_use_course()`
`leap_can_use_course()` (leergegevens)	open of lid of docent	`user_can_use_course()`
Documenten/fragmenten via map	`folder_course_id()` (LIMIT 1)	`folder_usable_by_user(folder)`: EXISTS een gekoppelde cursus waarvoor `user_can_use_course` (nodig voor de open variant, H8)
Server `userHasCourseAccess` / `canAccessCourseContent`	actief + zichtbaar = iedereen	zelfde regel als `user_can_use_course`; de pure functie `canAccessCourseContent` krijgt `audience` en `isMember`
Cursuskeuze (`ChooseCoursePage`)	alle zichtbare cursussen	twee lijsten: "Mijn cursussen" (lid) en "Open cursussen" (met knop Deelnemen). Externen zien alleen open cursussen.

Nieuwe route `POST /api/courses/:id/join`: alleen voor `audience = 'open'`, maakt een `course_members`-rij (student). Server-melding via `server/serverI18n.js`.

> **Risico.** Dit verandert wie wat ziet in heel LEAP. Daarom: (1) eerst backfill (4.1) met droge run, (2) een regressietest per policy (bestaande stijl: `server/__tests__/teacherPrivacy.test.js` + controle in de database met het testaccount in een teruggedraaide transactie, zoals `learningIntegrity`), (3) terugdraaiscript dat de oude policies letterlijk herstelt.

6. Inloggen via Canvas (LTI 1.3)

6.1 Stappen en routes

Route	Wat er gebeurt
`GET/POST /api/lti/login` (OIDC-initiatie)	Canvas stuurt `iss`, `login_hint`, `target_link_uri`, `lti_message_hint`, `client_id`. Controleer `iss` / `client_id` tegen `lti_platforms`. Maak `state` + `nonce` (willekeurig, 32 bytes), sla op in `lti_launch_states`, zet ook een cookie `lti_state` (HttpOnly, Secure, SameSite=None). Stuur de browser naar `auth_login_url` van Canvas met scope=openid, response_type=id_token, response_mode=form_post, prompt=none, redirect_uri, state, nonce, login_hint, lti_message_hint.
`POST /api/lti/launch` (redirect_uri)	Ontvang `id_token` + `state`. Controleer: state bestaat, niet verlopen, gelijk aan cookie (daarna verwijderen); JWT-handtekening met de JWKS van Canvas (`jose.createRemoteJWKSet`, cache); `iss`, `aud` = client_id (of `azp` bij meerdere aud), `exp` / `iat` (marge 60 s), `nonce` = opgeslagen nonce, `deployment_id` in de toegestane lijst, `message_type = LtiResourceLinkRequest`, `version = 1.3.0`. Daarna 6.2 t/m 6.5.
`GET /lti/done?code=…` (frontend-pagina)	De pagina ruilt de eenmalige code in via `POST /api/lti/handover`, krijgt access + refresh token, roept `supabase.auth.setSession()` aan en gaat naar het doel (cursus/pagina). Code is 60 s geldig en één keer bruikbaar; in de database alleen een hash.
`GET /.well-known/jwks.json`	Publieke sleutel van LEAP. Pas nodig voor de extra's (H13 fase 5); de private sleutel in Key Vault `kv-vu-leap`.

6.2 Persoon herkennen

1. Zoek `lti_identities` op (platform, `sub`). Gevonden → dat account (werk naam/e-mail/vunetid bij in het profiel als die veranderd zijn).
2. Niet gevonden → zoek een bestaand account op **VUnetID** (custom veld `vunetid`; vergelijk met e-maillokaal deel of een opgeslagen vunetid), dan op **e-mail** (alleen als Canvas een e-mail meestuurt). Gevonden → koppelen. Zo houdt wie al via de bulklijst een account had, zijn leerdagboek, quizgeschiedenis en prestaties.
3. Nog steeds niets → nieuw account via `supabaseAdmin.auth.admin.createUser({ email, email_confirm: true, user_metadata: { full_name } })`, `account_type = 'vu'`, geen activatiemail. Ontbreekt de e-mail (privacyinstelling): synthetisch adres `lti-<hash(sub)>@lti.leap.invalid`.
4. Een extern account wordt nooit via Canvas gekoppeld (account_type moet 'vu' zijn; anders duidelijke foutpagina en melding in het log).

6.3 Cursus koppelen

- Zoek `lti_course_links` op (platform, deployment, `context.id`).
- Gevonden → die LEAP-cursus (moet `audience = 'vu'` zijn).
- Niet gevonden en de gebruiker is **Instructor/TA** → pagina "Koppel deze Canvas-cursus" (`/lti/link`): kies een bestaande LEAP-cursus waar hij docent van is, of maak een nieuwe aan (naam = Canvas-cursusnaam). Daarna wordt de koppeling opgeslagen.
- Niet gevonden en de gebruiker is **student** → nette pagina: "Je docent heeft deze Canvas-cursus nog niet aan LEAP gekoppeld. Probeer het later opnieuw."
- Eén LEAP-cursus mag aan meerdere Canvas-cursussen hangen (bijvoorbeeld meerdere secties of jaren).

6.4 Lidmaatschap en rol (optie A)

- Rollen uit de claim `https://purl.imsglobal.org/spec/lti/claim/roles`: bevat `…membership#Instructor` of `…#TeachingAssistant` (of `ContentDeveloper`) → `teacher`; `…#Learner` → `student`. Instellingsrollen (`…/institution/person#…`) tellen niet.
- Upsert `course_members` met die rol bij elke start (een docent kan in Canvas student worden en andersom; bij een lagere rol omlaag zetten).
- Teacher en profiel nog `student` → profiel naar `docent` + regel in `user_audit_log` (changed_by = systeem/LTI). Nooit `admin`. Inlogcache vergeten na een rolwijziging.
- `profiles.last_active_course_id` = deze cursus.

6.5 Sessie aanmaken en doorsturen

- Geen eigen sessiemechanisme: `supabaseAdmin.auth.admin.generateLink({ type: 'magiclink', email })` (er wordt niets gemaild) → `hashed_token` → server roept `verifyOtp({ type: 'magiclink', token_hash })` aan → access + refresh token.
- Sla de sessie op onder een eenmalige code (`lti_handover_codes`, 60 s) en stuur de browser naar `/lti/done?code=…`. Tokens komen nooit in een URL.
- Doel: custom parameter `leap_page` (chat | explain | quiz | projects | studiecafe | feedback) uit de claim `…/claim/custom`, anders `/dashboard`. Alleen deze vaste lijst (geen vrije URL's: geen open redirect).
- LEAP opent in een **nieuw tabblad** (instelling bij Rob); binnen een Canvas-frame blokkeren browsers inloggen.

6.6 Implementatiekeuzes

- Bibliotheek: `jose` (JWT/JWKS controleren). Geen groot LTI-framework (ltijs vraagt MongoDB). Eigen module `server/lti/` met pure functies (`validateLaunchClaims`, `mapRoles`, `pickTarget`) + `registerLtiRoutes(app, deps)`, net als andere modules.
- Waar mogelijk de aanpak van Case Studio volgen (`App/src/lib/lti/` in die repository) zodat EDULAB één werkwijze heeft. Vraag Lothar bij de start om toegang of een kopie.
- Foutpagina's (`/lti/error?reason=…`) met begrijpelijke tekst in alle talen; details alleen in het serverlog. De PDF waarschuwt: kleine configuratiefouten geven vage fouten — log daarom per stap wat er misging (zonder tokens).
- Rate limiting op `/api/lti/*` (zelfde aanpak als `createSlidingWindowLimiter`).

7. Registratie voor externen

- **GoTrue-signup dicht** (`GOTRUE_DISABLE_SIGNUP=true` in de Azure-configuratie). Registratie loopt via een eigen route `POST /api/register` die `auth.admin.createUser` gebruikt. Zo bepaalt LEAP zelf wie zich mag registreren.
- Regels in die route: e-maildomein staat niet op de VU-lijst (anders code `useCanvas` → melding "VU-student of -medewerker? Log in via Canvas"); `account_type = 'external'`; e-mailbevestiging via de bestaande hook (`server/authEmailHook.js`); rate limit; registratie aan/uit met één beheerinstelling ("Externen mogen zich registreren").
- Na bevestigen en inloggen: de externe ziet alleen open cursussen en kiest "Deelnemen".
- Optioneel: een uitnodigingslink per open cursus (`/join/<code>`) die na registratie direct lid maakt.
- Inlogpagina: knop/uitleg "VU? Open LEAP via je cursus in Canvas", daaronder e-mail/wachtwoord (voor externen, docenten en beheerders) en "Account aanmaken (extern)".

8. Open variant van een cursus

Dezelfde cursus voor externen wordt een **aparte LEAP-cursus** met `audience = 'open'`. Zo komen externen nooit in de Canvas-cursus, hun leden, Studiecafé of analyses.

- Beheer → Cursussen → "Open variant maken" (alleen beheerder, of docent van de bron): maakt een nieuwe cursus en kopieert de **inrichting**: begrippen (met aliassen en bewijs), quizbronnen-mix, zoekgevoeligheid, chat-instructies, cursusinfo, projecten en persona's (zonder groepen, gesprekken of inleveringen). Geen leden, geen leergegevens.
- **Documenten niet dupliceren**: dezelfde mappen worden ook aan de open variant gekoppeld (`course_folder_assignments`). Daarvoor moet `folder_course_id()` (LIMIT 1) in de leesregels vervangen worden door `folder_usable_by_user()` (H5). Voordeel: geen dubbele verwerking en embeddings, één plek om materiaal bij te werken.
- Let op documentdoelen: `teacher_only` blijft overal alleen voor docenten; bestanden die niet voor externen bedoeld zijn, kun je in de variant per map uitzetten (eigen map voor VU-only materiaal).
- De variant leeft daarna zelfstandig (wijzigingen in begrippen of projecten gaan niet automatisch mee). Later eventueel "bijwerken vanuit bron".

9. Beheer, teksten en documentatie

- Cursusinstellingen: "Voor wie" (VU via Canvas / Open voor externen), lijst gekoppelde Canvas-cursussen (ontkoppelen kan), "Open variant maken".
- Instellingen (beheerder): externe registratie aan/uit, lijst VU-domeinen, Canvas-koppeling (status van `lti_platforms`, laatste geslaagde start).
- Gebruikers (beheerder): kolom accounttype, en of het account aan Canvas gekoppeld is.
- Alle teksten via i18n (`nl.json` bron, `en.json` met de hand, rest via `scripts/i18n-generate.mjs`); servermeldingen via `server/serverI18n.js`; nieuwe hulpteksten in `src/help/helpTopics.ts`; Ontwerphulp: `ADMIN_SECTIONS` / `OTHER_PAGES` bijwerken; `server/myData.js`: `lti_identities` in `EXPORT_SOURCES` of `NOT_EXPORTED` (test faalt anders).
- Handleiding (`docs/handleiding/handleiding.html` + PDF): hoofdstuk "Via Canvas" en "Open cursussen". CLAUDE.md: sectie met de nieuwe regels.

10. Configuratie: wat Rob nodig heeft (Developer Key, LTI 1.3)

Veld	Waarde
Redirect URI(s)	`https://leap.vu-edulab.nl/api/lti/launch`
Target Link URI	`https://leap.vu-edulab.nl/api/lti/launch`
OpenID Connect Initiation URL	`https://leap.vu-edulab.nl/api/lti/login`
JWK method / Public JWK URL	`https://leap.vu-edulab.nl/.well-known/jwks.json`
Privacy level	**Public** (naam en e-mail)
Custom fields	`vunetid=$Canvas.user.loginId` `course_name=$Canvas.course.name`
Placements	Course Navigation ("LEAP"), Assignment Selection / Link Selection; *open in new tab*
LTI Advantage services	Fase 1: geen. Later eventueel Names and Roles (klassenlijst).

Van Rob terug nodig: **client_id**, **deployment_id**(s), en bevestiging van **issuer** en de Canvas-adressen voor autorisatie, token en JWKS (bij Instructure-gehoste Canvas meestal issuer `https://canvas.instructure.com`, autorisatie `https://sso.canvaslms.com/api/lti/authorize_redirect`, JWKS `https://sso.canvaslms.com/api/lti/security/jwks` — **bij Rob verifiëren**). Er worden geen geheimen uitgewisseld. Die waarden komen in `lti_platforms` (niet in de repo; de repo is openbaar).

Lokaal testen: `.env`-variabele `LTI_DEV_PLATFORM` voor een simulator (bijv. de IMS LTI 1.3 reference implementation of saltire.lti.app). Er is geen gratis test-Canvas.

11. Privacy

- Van Canvas ontvangen we per start: anoniem Canvas-id (`sub`), naam, e-mail, VUnetID, Canvas-cursus (id + naam) en rol. Opslaan: koppeling in `lti_identities` en `lti_course_links`; naam/e-mail in het profiel (zoals nu). Geen cijfers, geen andere Canvas-gegevens.
- De bestaande privacyregel voor docenten blijft gelden: een docent ziet wie in zijn cursus zit en in welke projectgroep, verder niets.
- Externen: gescheiden van VU-cursussen; zij zien geen VU-studenten en andersom alleen binnen een open cursus waar beiden lid zijn.
- DPIA aanvullen: bron van de gegevens (Canvas), grondslag, bewaartermijn van koppelingen (verwijderd met het account; "Mijn gegevens" toont ze), en de nieuwe groep betrokkenen (externen).

12. Eerst opnieuw controleren bij de start van de bouw

- Branch en stand: `git log`, openstaande migraties (`node scripts/migrate.mjs --status`), tests en typecheck als nulmeting.
- Of de bevindingen uit H2 nog kloppen (vooral policies op `courses`, `course_content_is_public`, `folder_course_id`, de signup-instelling).
- Of Rob de gegevens uit H10 al heeft aangeleverd; zo niet, fase 1 met de simulator bouwen.
- Of Case Studio-code beschikbaar is om op aan te sluiten.

- Aantallen voor de backfill (droge run) aan Lothar laten zien vóór het uitvoeren.

13. Bouwchecklist, tests en fasering

Fase	Inhoud	Klaar als
1. Publiek van cursussen	Migratie 4.1 met backfill (droge run eerst), toegangsregels H5, cursuskeuze met "Mijn cursussen" + "Open cursussen", "Deelnemen", beheerinstelling "Voor wie". Bestaande cursussen worden `vu`.	Testaccount ziet alleen cursussen waar het lid van is + open; VU-cursus onzichtbaar voor extern; niemand verliest toegang tot een cursus waarin hij actief was (controle op aantallen).
2. LTI-basis	Migratie 4.2, `server/lti/`, routes 6.1, herkennen 6.2, koppelen 6.3 (pagina voor docent), rol 6.4, sessie 6.5, foutpagina's. Getest met simulator.	Simulator-start als student en als docent komt ingelogd in de juiste cursus; vervalste/oude/verkeerde tokens worden geweigerd (tests per controle).
3. Externe registratie	Signup dicht in GoTrue, `/api/register`, VU-domeinen geweigerd, open cursussen + uitnodigingslink, inlogpagina aangepast.	Extern kan registreren en alleen open cursussen zien; VU-adres krijgt "Log in via Canvas"; registratie uit = geen nieuwe accounts.
4. Pilot met VU-Canvas	Registratie door Rob, één testcursus, docent koppelt, studenten starten. Daarna zelfregistratie voor VU-adressen definitief uit.	Een echte Canvas-student en -docent komen binnen; bestaande accounts worden herkend (VUnetID/e-mail).
5. Open variant	`folder_usable_by_user`, "Open variant maken" (H8).	Variant heeft dezelfde documenten zonder herverwerking, eigen leden, geen leergegevens van de bron.
6. Later (optioneel)	Names and Roles (klassenlijst: wie is nog niet in LEAP geweest), Deep Linking (docent kiest bij een Canvas-opdracht een LEAP-project of -quiz). Cijfers terugsturen: niet (LEAP is formatief).	Apart besluit.

Tests die minimaal nodig zijn

- Pure functies: claimcontrole (iss/aud/azp/exp/nonce/deployment/message_type/version), rolvertaling, doelpagina (alleen vaste lijst), e-maildomein-check.
- Routes met nagebootste database (stijl `server/__tests__/analytics.test.js`): start met geldig token → overdrachtscode; ongeldige handtekening, verlopen token, hergebruikte state/nonce, onbekende deployment → geweigerd; student zonder cursuskoppeling → nette melding; extern account via Canvas → geweigerd.
- Database (testaccount, teruggedraaide transactie, stijl `learningIntegrity`): extern niet in VU-cursus; open cursus wel zichtbaar; VU-cursus niet zichtbaar voor niet-lid; fragmenten van een gedeelde map leesbaar via de open variant.

- Bestaande suites blijven groen (bekende uitzonderingen: 3 tests die een lege `.env` verwachten, 3 Studiecafé-tests); typecheck niet hoger dan de nulmeting.
- UI: `npm run ui:audit` voor de nieuwe pagina's (cursuskeuze, koppelpagina, registratie).

Terugdraaien

- Per migratie een terugdraaiscript; fase 1 herstelt de oude policies letterlijk en laat de backfill-lidmaatschappen staan (onschadelijk).
- LTI kan uit door `lti_platforms.active = false` (de routes weigeren dan netjes); registratie terug open met de beheerinstelling en `GOTRUE_DISABLE_SIGNUP=false`.
- Zoals altijd: pushen naar main alleen als Lothar dat zegt; DB-wijzigingen tijdens testen alleen met momentopname.

Achtergrond: "Canvas and LTI, in plain terms" (EDULAB) en de huidige code van LEAP-VU per 13 oktober 2026 (commit cee6fbe op main).